Do You Know What's Inside?

Why software transparency has to become the industry default, and an open census that starts now



Ben Heise · **Xenolith project**

8 November 2026 · Version 1.0 · Public (TLP:CLEAR)

AGENDA

What we'll cover

01 **The question every incident asks**
Why "are we affected?" still takes weeks

02 **How we got here**
Six incidents, 2014 to 2024

03 **A patchwork of rules**
Sector by sector, and mostly private

04 **The verification gap**
What the paperwork says versus what ships

05 **Leaders who publish**
The transparency ladder, and why it pays

06 **An open census**
Xenolith, and how it was tested

07 **What each of us can do**
Vendors, buyers and regulators

About this talk

Format: 35-minute talk, then questions

For: product vendors, buyers, regulators and security practitioners

Terms: SBOM is a software bill of materials. VEX states whether a product is affected by a vulnerability. CSAF is the standard format for machine-readable advisories.

Every figure is cited on its slide; the full source list is on slides 18 and 19.

OVERVIEW

The bottom line

1

We keep asking the same question

Every major incident starts with “which of our products contain it?”, and most organizations still can’t answer quickly.

2

The rules won’t answer it for us

Requirements differ by sector and country, and almost none require vendors to publish what their products contain.

3

Transparency is a competitive edge

Vendors who publish SBOMs and VEX earn trust before the next incident. An open census can check everyone else.

The ask: publish machine-readable SBOMs and VEX for every release, and help build a public, verifiable census of what products contain.

Summary of the argument; evidence follows on slides 4 to 15.

Every incident asks the same question

“Which of the products we already run have it inside?”

No inventory

Equifax had no inventory showing where, or whether, it ran Apache Struts when the 2017 fix landed.

U.S. Senate PSI, 2019 [3]

Unknown

Belgium’s cyber centre on libwebp in 2023: “It is unknown how many applications are affected.”

CCB advisory 2023-109 [9]

~200,000

Devices still exposed to Heartbleed nearly three years after the fix was released.

Shodan, January 2017 [6]

Sources: [3] U.S. Senate PSI, 2019; [6] Shodan via SecurityWeek, 2017; [9] Centre for Cybersecurity Belgium, 2023.

A decade of the same blind spot



2014 — Heartbleed
OpenSSL

About 17% of trusted HTTPS sites exposed; ~200,000 devices still vulnerable in 2017.

2017 — Equifax
Apache Struts

Fix out 7 March; attackers inside from 13 May. Data on 145+ million people taken.

2020 — SolarWinds
Orion build system

Backdoor added in the build, not the source. Fewer than 18,000 customers installed it.

2021 — Log4Shell
Log4j

A CVSS 10.0 flaw in a logging library integrated into millions of systems.

2023 — libwebp
libwebp

Exploited image-decoder flaw inside browsers and Electron, CEF and Flutter apps.

2024 — xz utils
liblzma

Multi-year backdoor campaign, found by an engineer chasing slow SSH logins.

Different components, different attackers, the same blind spot.

Sources: [2] CSRB, 2022; [3] Senate PSI, 2019; [4] GAO-18-559; [5] Netcraft, 2014; [6] Shodan, 2017; [7] SolarWinds 8-K, 2020; [8] Freund, 2024; [9] CCB, 2023.

Log4Shell: the cost of not knowing

10.0

CVSS score: remote code execution in a library that ships almost everywhere

Hundreds

of millions of devices likely affected, CISA officials warned industry

33,000

hours one federal cabinet department spent on its Log4j response

10+ years

how long the CSRB said vulnerable Log4j versions may remain in systems

> *“One of the most serious I’ve seen in my entire career.*
>
> Jen Easterly, CISA Director, briefing industry on 13 December 2021 [1]

The CSRB later called Log4j an “endemic vulnerability” [2].

Sources: [1] CISA briefing reported by CyberScoop, 13 December 2021; [2] Cyber Safety Review Board, July 2022.

Three failures, one root cause

Embedded and unlisted
Heartbleed · libwebp

A component compiled into products that never said it was there.

No inventory
Equifax · Log4Shell

Owners could not say where the component ran, so scans looked in the wrong places.

Compromised builds
SolarWinds · xz utils

What shipped differed from what the source said; only the artifact told the truth.

Root cause: no shared, verifiable record of what products contain. Every organization rebuilds the answer alone, under pressure, and then throws it away.

Sources: [2] CSRB, 2022; [3] Senate PSI, 2019; [5] Netcraft, 2014; [7] SolarWinds 8-K, 2020; [8] Freund, 2024; [9] CCB, 2023.

Rules differ by sector, and stay private

Sector	Instrument	What it requires	Public?	In force
Medical devices (US)	FD&C Act §524B, enforced by FDA	An SBOM in premarket submissions for “cyber devices”	**No: filed with FDA**	29 Mar 2023
Products with digital elements (EU)	Cyber Resilience Act, (EU) 2024/2847	An SBOM in the technical documentation	**No: not obliged to publish**	11 Dec 2027
Payment card environments	PCI DSS 4.0, requirement 6.3.2	Inventory of bespoke and custom software and its third-party components	**No: for assessors**	31 Mar 2025
US federal purchasing	EO 14028, now OMB M-26-05	Nothing fixed: agencies “may” require an SBOM by contract	**No**	Mandate rescinded 23 Jan 2026
Industrial, enterprise, consumer IoT	Guidance only: NTIA 2021, CISA 2025 draft, CISA/NSA + 19 partners	Nothing binding	**No**	—

Sources: [10] FDA; [11] Regulation (EU) 2024/2847; [12] PCI DSS v4.0; [13] OMB M-26-05; [14] NTIA, 2021; [15] CISA, 2025; [16] CISA, NSA and partners, 2025.

Mandates are moving in opposite directions

Tightening

- FDA may refuse premarket submissions for cyber devices that lack required cybersecurity content (since 1 Oct 2023)
- PCI DSS component inventory mandatory from 31 Mar 2025
- EU CRA: vulnerability reporting from 11 Sep 2026, SBOM duty from 11 Dec 2027, fines up to €15M or 2.5% of turnover
- CISA's 2025 draft adds component hash, license, tool name and generation context

Loosening

- OMB M-26-05 rescinded the federal secure-software attestation memos (23 Jan 2026)
- SBOMs became an agency-by-agency choice; CISA templates are no longer required
- Agencies must still keep a complete software and hardware inventory, which depends on vendor data

One product sold to US hospitals, card processors, EU customers and federal agencies answers to four regimes, and none requires the vendor to publish.

Sources: [10] FDA; [11] Regulation (EU) 2024/2847; [12] PCI DSS v4.0; [13] OMB M-26-05, 23 January 2026; [15] CISA 2025 draft minimum elements.

Paperwork and products drift apart

Product	The maker's documents say	The shipped files contain	Match
Visual Studio Code 1.95.3, code-tunnel CLI	Notices name only the Rust openssl crate	OpenSSL 3.1.4, statically linked	No
Elasticsearch 8.15.0	NOTICE.txt: commons-logging 1.1.1	commons-logging 1.2 in every bundled jar	No
Wireshark 4.4.19 for Windows	Build script: c-ares 1.28.1	cares.dll reports 1.27.0	No
Netgear R7000 firmware 1.0.11.136 (2022)	No public component list found	curl 7.36.0 (from 2014), OpenSSL 1.0.2h, BusyBox 1.22.1*	Unknown
Splunk Universal Forwarder 9.2.1	Advisory SVD-2024-0304: OpenSSL 1.0.2zj, curl 8.5.0	OpenSSL 1.0.2zj, curl 8.5.0	Yes

Presence is not exposure: a listed component can be unreachable or already patched. * A scan result, not confirmed against a GPL source archive.

Source: [24] Xenolith real-artifact scans with xenolith-scan, November 2026 (design/xenolith-scan.md).

Why checking is harder than it sounds

Static linking and vendoring

Copies compiled into a binary leave no package metadata for scanners to read.

Packed formats

Firmware and installers hide their files. Wireshark's MSI showed 0 components until its tables were decoded, then 55.

Notices are legal documents

Written for license compliance, not inventory, they drift from what is actually built.

Inconsistent identity

zlib-ng announces itself as zlib; a DLL calls itself "The c-ares library". Matching takes judgment.

SBOMs kept private

Where SBOMs exist, they go to regulators or under confidentiality terms, out of customers' reach.

Builds can differ from source

SolarWinds' backdoor sat in the build system, not the source repository. Only the artifact tells the truth.

Sources: [7] SolarWinds 8-K, 2020; [11] Regulation (EU) 2024/2847, recitals; [20] Cisco SBOM request terms; [24] Xenolith scans, November 2026.

The transparency ladder

LEVEL 1

Readable disclosures

Open source notices and security disclosure forms.

Philips: MDS² security forms for its medical devices, and a stated aim of an SBOM for every product.

LEVEL 2

Machine-readable advisories

CSAF advisories and VEX: affected, fixed or not affected.

Siemens, Microsoft, Cisco: CSAF feeds. Siemens has listed “known not affected” products since June 2025.

LEVEL 3

SBOMs on request

Customers can ask, usually under confidentiality terms.

Cisco: SPDX SBOMs since June 2023 for supported on-premises software released after September 2022.

LEVEL 4

Public SBOMs and VEX

Anyone can download and check, release by release.

Red Hat: SBOMs, VEX and OSV under CC BY 4.0

Kubernetes: a signed SBOM per release

Docker: SBOM, VEX and SLSA L3 provenance per Hardened Image

Sources: [17] Red Hat; [18] Kubernetes; [19] Docker; [20] Cisco; [21] Siemens ProductCERT; [22] Philips; [23] Microsoft; [24] Xenolith CSAF crawler.

Knowing what's inside is an advantage

Same flaw, same month, different outcomes (2017)

TransUnion and Experian
Used accurate IT asset inventories to find their vulnerable Struts systems; TransUnion began patching within days.

Equifax
Had no inventory of where it used Struts. The breach exposed data on more than 145 million people.

U.S. Senate Permanent Subcommittee on Investigations, 2019 [3]

What publishing earns a vendor

Faster answers
"Are we affected?" becomes a lookup for customers, not a support ticket.

Procurement readiness
FDA, PCI DSS and the EU CRA already demand this evidence.

Trust that survives scrutiny
Public data can be checked, and data that checks out compounds trust.

Authority to say "not affected"
VEX ends the scramble for customers and support teams alike.

Sources: [3] U.S. Senate PSI, 2019; [4] GAO-18-559, 2018; [10] FDA; [11] EU CRA; [12] PCI DSS v4.0.

Xenolith: an open census of what's inside

A xenolith is a fragment of foreign rock sealed inside another. Products carry other people's components the same way.

1 · COLLECT
Gather what vendors publish

- CSAF and VEX feeds: Cisco, Microsoft, Red Hat, Siemens, BSI's aggregator
- Open source notices from NetApp, Palo Alto Networks, F5, Apple and more
- SBOMs submitted by vendors and the community

2 · VERIFY
Check the shipped artifact

- xenolith-scan: one offline command; nothing is executed
- Unpacks installers, firmware, archives and container images
- Finds statically linked copies; compares with the maker's notices

3 · PUBLISH
Make the answer public

- Searchable by product, component and version
- Every entry links to its source
- Shows presence, not exposure: a lead to check, not a verdict

Open source, Apache-2.0 · github.com/benheise/Xenolith · benheise.github.io/Xenolith

Source: [24] Xenolith repository, README and design/xenolith-scan.md, November 2026.

Tested against real products

24

real artifacts with maker-published ground truth, closed-source products included

93%

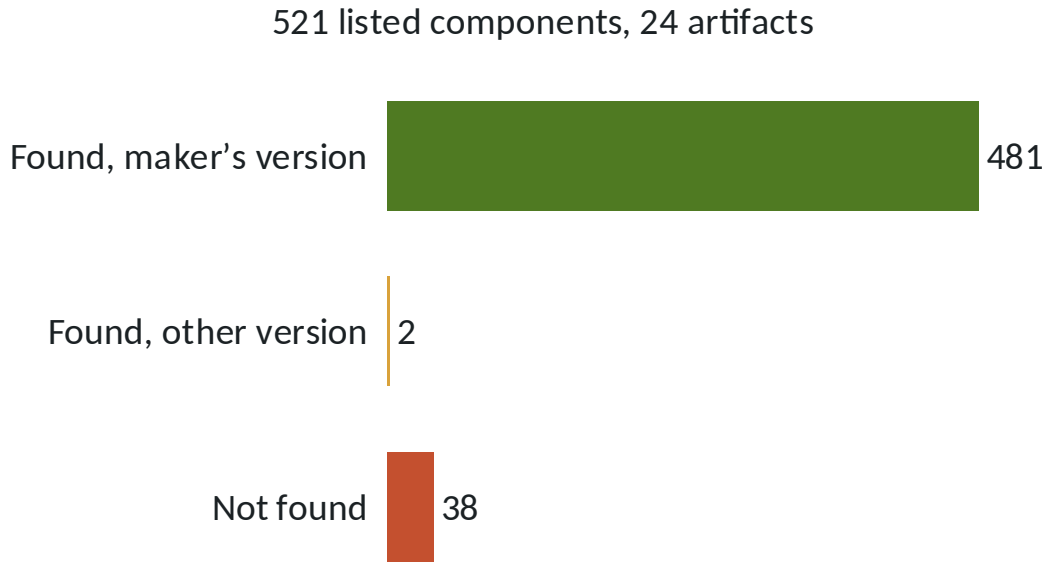
of listed components found (483 of 521)

481/483

found components reported at the maker's exact version

39/39

watchlist components detected, such as OpenSSL, curl, Log4j and libwebp



The corpus includes Splunk Universal Forwarder, Visual Studio Code, Wireshark's NSIS and MSI installers, Elasticsearch, OpenWrt, Debian packages and Python wheels. The misses are libraries with no fingerprint yet, such as libpng, FreeType and OpenLDAP.

Source: [24] xenolith-scan eval on scan/corpus/manifest.yaml, November 2026.

What each of us can do

Vendors

- Publish an SBOM and VEX for every release at a stable public URL
- Generate SBOMs from the artifact you ship, not only the source tree
- Keep notices in step with builds, and welcome independent checks

Buyers

- Ask for public SBOM and VEX in every RFP and renewal
- Give weight to vendors who already publish; ask the rest why not
- Scan what you run and contribute the results to the census

Regulators and standards bodies

- Make publication the default, and justify exceptions narrowly
- Align sectors on one set of minimum elements
- Accept independent verification as evidence

Recommendations are the author's own, drawing on the evidence in slides 4 to 15.

Make day one a lookup, not a scramble

The next Log4Shell is already shipping inside something you run. Let’s know where before it is announced.

Code and data: github.com/benheise/Xenolith

Census: benheise.github.io/Xenolith

Contribute an SBOM: xenolith-scan scan <product>



Thank you. Questions?

REFERENCES

Sources (1 of 2)

[1] CyberScoop (T. Starks), “CISA warns ‘most serious’ Log4j vulnerability likely to affect hundreds of millions of devices,” 13 Dec 2021. https://www.cyberscoop.com/log4j-cisa-easterly-most-serious/

[2] Cyber Safety Review Board, “Review of the December 2021 Log4j Event,” 11 Jul 2022. https://www.cisa.gov/sites/default/files/publications/CSRB-Report-on-Log4-July-11-2022_508.pdf

[3] U.S. Senate Permanent Subcommittee on Investigations, “How Equifax Neglected Cybersecurity and Suffered a Devastating Data Breach,” staff report, 2019. https://www.hsgac.senate.gov/imo/media/doc/FINAL%20Equifax%20Report.pdf

[4] U.S. GAO, “Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach,” GAO-18-559, 2018. https://www.gao.gov/products/gao-18-559

[5] Netcraft, “Half a million widely trusted websites vulnerable to Heartbleed bug,” 8 Apr 2014. https://news.netcraft.com/archives/2014/04/08/half-a-million-widely-trusted-websites-vulnerable-to-heartbleed-bug.html

[6] SecurityWeek, “Heartbleed Still Affects 200,000 Devices: Shodan,” Jan 2017. https://www.securityweek.com/heartbleed-still-affects-200000-devices-shodan

[7] SolarWinds Corp., Form 8-K, 14 Dec 2020. https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm

[8] A. Freund, “backdoor in upstream xz/liblzma leading to ssh server compromise,” oss-security, 29 Mar 2024. https://www.openwall.com/lists/oss-security/2024/03/29/4

[9] Centre for Cybersecurity Belgium, Advisory 2023-109, critical actively exploited vulnerability in libwebp, 18 Sep 2023. https://ccb.belgium.be/advisories/warning-critical-actively-exploited-vulnerability-libwebp-affecting-many-products

[10] U.S. FDA, “Cybersecurity in Medical Devices Frequently Asked Questions (FAQs).” https://www.fda.gov/medical-devices/digital-health-center-excellence/cybersecurity-medical-devices-frequently-asked-questions-faqs

[11] Regulation (EU) 2024/2847 (Cyber Resilience Act). https://eur-lex.europa.eu/eli/reg/2024/2847/oj

[12] PCI Security Standards Council, PCI DSS v4.0, requirement 6.3.2. https://www.pcisecuritystandards.org/document_library/

All links checked 8 November 2026. Bracketed numbers on earlier slides refer to this list.

REFERENCES

Sources (2 of 2)

[13] U.S. OMB, M-26-05, “Adopting a Risk-based Approach to Software and Hardware Security,” 23 Jan 2026. https://www.whitehouse.gov/wp-content/uploads/2026/01/M-26-05-Adopting-a-Risk-based-Approach-to-Software-and-Hardware-Security.pdf

[14] NTIA, “The Minimum Elements for a Software Bill of Materials (SBOM),” 12 Jul 2021. https://www.ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom

[15] CISA, “2025 Minimum Elements for a Software Bill of Materials (SBOM),” public comment draft, Aug 2025. https://www.cisa.gov/resources-tools/resources/2025-minimum-elements-software-bill-materials-sbom

[16] CISA, NSA and 19 international partners, “A Shared Vision of Software Bill of Materials (SBOM) for Cybersecurity,” 3 Sep 2025. https://www.cisa.gov/resources-tools/resources/shared-vision-software-bill-materials-sbom-cybersecurity

[17] Red Hat Product Security, “Security Data” (SBOM, CSAF/VEX and OSV; CC BY 4.0). https://access.redhat.com/security/data

[18] Kubernetes release engineering, signed SPDX SBOMs for every release (for example sbom.k8s.io/v1.23.0/release), kubernetes/release issue 1837. https://github.com/kubernetes/release/issues/1837

[19] Docker, “Docker Hardened Images features.” https://docs.docker.com/dhi/features/

[20] Cisco, “Demonstrating Transparency Through Software Bill of Materials (SBOM),” 2023, and “SBOM Request Form Instructions.” https://blogs.cisco.com/security/demonstrating-transparency-through-software-bill-of-materials-sbom

[21] Siemens ProductCERT, security advisories in HTML and CSAF. https://cert-portal.siemens.com/

[22] Philips, Product Security (MDS² forms); M. McNeil, “Establishing Best Practices for a Comprehensive Risk-based Product Security Program,” CIOReview. https://www.philips.com/productsecurity

[23] Microsoft, sbom-tool (open source SBOM generator). https://github.com/microsoft/sbom-tool

[24] Xenolith project: repository, README and design/xenolith-scan.md (real-artifact proofs), November 2026. https://github.com/benheise/Xenolith

All links checked 8 November 2026. Bracketed numbers on earlier slides refer to this list.

DOCUMENT CONTROL

Document control and notices

Title	Do You Know What's Inside? Software transparency and an open census
Author	Ben Heise
Version	1.0
Date	8 November 2026
Status	Final, for presentation
Classification	Public (TLP:CLEAR)
Location	docs/presentations/ in the Xenolith repository
Formats	PowerPoint (.pptx) and PDF
License	Apache-2.0, as the repository

Version history

Version	Date	Author	Change
1.0	8 Nov 2026	Ben Heise	First release

Notices

- Findings show that a component is present, not that a product is exploitable.
- Product and company names are trademarks of their owners. Mentions are factual and imply no endorsement.
- Facts are current as of 8 November 2026. This deck is not legal advice.

Corrections and questions: open an issue at github.com/benheise/Xenolith/issues.